

PASSWORD PROTECTION POLICY

Based on SANS Password Construction Standard, April 2025
General Category

Version	Effective Date	Document Owner	Status
1.0	March 28, 2026	Noe Valencia	Active

Do not distribute externally.

1. Purpose

This Password Protection Policy establishes standards and guidelines for the creation, management, protection, and periodic assessment of passwords across all organizational systems and accounts. Compromised credentials remain the single leading cause of data breaches worldwide. According to the Verizon 2025 Data Breach Investigations Report, stolen, weak, or reused passwords are involved in 88% of basic web application attacks and 22% of all breaches. In 2025 alone, over 5 billion accounts were compromised globally.

This policy provides a clear, enforceable framework that enables personnel to create strong credentials, reduces the burden of password management through approved tooling, mandates multi-factor authentication, and establishes screening controls that prevent the use of known compromised passwords. By aligning with NIST SP 800-63B, Microsoft's modern authentication guidance, and current industry best practices, this policy protects organizational assets without imposing unnecessary friction on users.

2. Scope

This policy applies to all employees, contractors, consultants, temporary workers, and third-party personnel with access to any organizational system, account, or resource. It covers all password-protected accounts and credentials including:

- User-level accounts on all organizational systems and platforms
- System-level and service accounts, including automated processes and scripts
- Web application and SaaS platform accounts
- Email and collaboration platform accounts
- Privileged and administrative accounts
- VPN, remote access, and network device accounts
- Voicemail, screen saver, and local device protection
- API keys, tokens, and other programmatic credentials

Compliance with this policy is mandatory for all in-scope individuals. Deviations require written approval through the exception process defined in Section 12.

3. Principle Statement

Password security is managed on the principle that length is more important than complexity, usability supports compliance, and no password policy is complete without multi-factor authentication. Forcing users into rigid, frequently-changing complexity requirements has been shown by NIST and Microsoft research to produce weaker security outcomes, not stronger ones, because users respond with predictable patterns, minor variations, and credential reuse.

This policy reflects the modern consensus: require long passphrases over short complex strings, eliminate arbitrary expiration cycles, screen all passwords against known breach databases, mandate MFA on all sensitive systems, and use approved password managers to eliminate the human memory burden that drives poor credential hygiene. Passwords are a single layer of a defense-in-depth strategy, not a complete solution on their own.

4. Senior Management Commitment

Senior management is fully committed to the implementation and enforcement of this Password Protection Policy. We recognize that credential compromise is the most common entry point for attackers and that protecting organizational accounts requires both strong technical controls and a user-friendly approach that personnel will actually follow.

Senior management commits to providing approved password manager tools, MFA infrastructure, and training resources necessary to support compliance with this policy. This policy will be reviewed annually and updated to reflect changes in NIST guidance, industry standards, and the threat environment.

Signed: _____ Date: _____
Chief Information Security Officer / Senior IT Leadership

5. How Similar Organizations Handle Password Protection

Research into peer organizations and regulatory frameworks reveals consistent and evolving approaches to password policy that inform the standards defined in this policy.

5.1 University Sector

Major universities have moved away from mandatory 90-day password rotation in line with NIST SP 800-63B guidance, recognizing that forced changes produce weaker, more predictable credentials. Instead, institutions like MIT and Carnegie Mellon require a minimum passphrase length of 12 to 16 characters, mandate MFA for all systems handling regulated data (FERPA, HIPAA, research data), integrate Active Directory with breached password screening tools such as Specops or HaveIBeenPwned API, and provide institutionally licensed password managers to all students and staff. Password changes are only required upon evidence of compromise rather than on a calendar schedule.

5.2 Federal Government, NIST SP 800-63B and Agency Implementation

The National Institute of Standards and Technology's Digital Identity Guidelines (NIST SP 800-63B), last significantly updated in 2024, represent the most authoritative and widely referenced password standard in the industry. Key NIST requirements include a minimum password length of 8 characters (with 15 or more strongly recommended), support for passwords up to at least 64 characters to enable passphrases, no mandatory complexity rules (uppercase, special characters) that do not demonstrably increase security, no required periodic password rotation unless compromise is suspected, mandatory screening of new passwords against known-compromised credential lists, and no password hints or knowledge-based authentication questions. Federal agencies are required to implement these standards and the private sector increasingly adopts them as the baseline.

5.3 Financial Services Sector, PCI DSS and Microsoft Enterprise

Organizations subject to PCI DSS v4.0 must enforce a minimum 12-character password length for accounts accessing cardholder data environments, implement account lockout after no more than 10 failed attempts, and require MFA for all administrative and remote access. Microsoft's enterprise password guidance for 2025 aligns closely with NIST, recommending the elimination of complexity requirements, banning password expiration unless compromise is suspected, enforcing MFA as the primary defense layer, and using Azure Active Directory's Password

Protection feature to block known weak and compromised passwords across the enterprise. Microsoft's data shows that accounts with MFA enabled are more than 99.9% less likely to be compromised, making it the single most impactful password-adjacent control available.

6. Current Industry Trends (2026)

This policy reflects the most current thinking on credential security as of 2026.

6.1 Length Over Complexity

The industry has decisively moved away from arbitrary complexity requirements toward length-based standards. In 2026, a standard consumer-grade GPU can crack an 8-character password in under 12 minutes regardless of its complexity. A 16-character passphrase composed of unrelated common words, such as metal-lemon-49-blanket, is exponentially harder to crack and far easier for users to remember. NIST, Microsoft, and the UK's National Cyber Security Centre all now recommend this approach. Complexity rules without length requirements actively harm security by encouraging predictable substitution patterns that AI-enhanced cracking tools are specifically designed to exploit.

6.2 Elimination of Mandatory Periodic Rotation

Mandatory 30, 60, or 90-day password rotation cycles are now recognized by NIST and Microsoft as counterproductive. Research consistently shows that users respond to forced rotation by making minimal changes to existing passwords, such as incrementing a number or changing a single character, which provides no real security benefit. Both NIST SP 800-63B and Microsoft's current guidance recommend that passwords only be changed upon evidence or suspicion of compromise, not on a calendar schedule. This policy adopts that standard for standard user accounts, while retaining annual rotation requirements for privileged accounts as a reasonable intermediate control.

6.3 Breached Password Screening

Modern authentication systems now integrate with breach databases such as HaveIBeenPwned, which contains over 10 billion compromised credentials, to screen passwords at creation and login time. If a proposed password appears in known breach data, it is rejected regardless of its length or complexity. Specops Software's 2026 research found that predictable behavior such as uppercase first letters, numbers at the end, and common substitutions remains the dominant pattern in breached corporate credentials, confirming that composition rules without breach screening provide a false sense of security.

6.4 MFA as the Primary Defense Layer

Multi-factor authentication has become the single most impactful control in the credential security stack. Microsoft's data shows that MFA prevents over 99.9% of credential-based account compromises. However, the industry has also identified new attack vectors against MFA including MFA fatigue attacks, where attackers flood users with push notifications hoping for accidental approval, and SIM-swapping attacks against SMS-based MFA. In 2026, the standard is moving toward number-matching MFA (where users must enter a code from their screen into the authenticator app) and phishing-resistant MFA such as FIDO2 hardware keys and passkeys, which eliminate the push notification attack surface entirely.

6.5 Password Managers as Organizational Infrastructure

The average employee manages over 191 passwords across work accounts. Without a password manager, credential reuse is virtually inevitable. Enterprise password managers such as 1Password, Bitwarden, and LastPass Business are now considered standard organizational infrastructure, not optional personal tools. They enable unique, high-entropy passwords for every account, reduce helpdesk burden from forgotten passwords, support secure credential sharing within teams, and provide audit trails for credential access. Organizations that provide approved enterprise password managers see measurable improvements in password hygiene and reduction in credential-related incidents.

6.6 The Passwordless Horizon

While passwords will remain embedded in enterprise environments for the foreseeable future due to legacy systems and recovery workflows, the industry is actively moving toward passwordless authentication. FIDO2, WebAuthn, and passkeys eliminate shared secrets entirely by using public-key cryptography tied to a device or biometric. Microsoft, Apple, and Google have all committed to passkey support across their platforms. Organizations should plan for a hybrid environment in 2026 and beyond where passwords coexist with passwordless methods, and password policies must address both.

7. Roles and Responsibilities

Role	Primary Responsibilities
IT Security Manager	Policy owner; annual review; approves exceptions; manages breached password screening tools; oversees MFA deployment
Systems Administrator	Enforces technical password controls in Active Directory and all platforms; manages account lockout policies; administers enterprise password manager
IT Help Desk	Handles password reset requests following identity verification procedures; reports patterns of suspicious reset activity to IT Security Manager
All Employees and Contractors	Must comply with all password standards; must use approved password manager; must enroll in MFA; must never share credentials
Managers and Supervisors	Responsible for ensuring team members complete password security training; must immediately report suspected credential compromise

8. Password Standards and Safeguards

The following standards are derived from the SANS Password Construction Standard (April 2025) and significantly expanded with controls aligned to NIST SP 800-63B, Microsoft enterprise guidance, and current industry best practice.

8.1 Password Construction Requirements

Control	Standard	Rationale and Industry Alignment
PWD-01	All work-related passwords must be a minimum of 16 characters in length. Passwords up to 64 characters must be	The SANS template mandates 16 characters as the minimum. NIST SP 800-63B recommends a minimum of 8 but strongly

Control	Standard	Rationale and Industry Alignment
	supported on all systems to enable passphrase use.	encourages 15 or more. In 2026, a GPU can crack an 8-character password in under 12 minutes. At 16 characters, brute-force time extends to centuries.
PWD-02	Passphrases composed of multiple unrelated words are the preferred password format. Examples include metal-lemon-49-blanket or sunrise-cable-forest-rain. Users must not use predictable patterns such as Company2026 or seasonal passwords like Spring2026.	NIST SP 800-63B, SANS, and Microsoft all recommend passphrases over short complex strings. Passphrases are easier to remember, less likely to be written down, and harder to crack than short complex passwords. AI-enhanced cracking tools specifically exploit predictable patterns.
PWD-03	Passwords must not be reused across organizational accounts. Users must not reuse any of their last 10 passwords on any given system.	Password reuse is a primary driver of credential stuffing attacks. A breach of one system immediately compromises all accounts sharing the same password. CIS Control 5 and PCI DSS v4.0 both require password history enforcement to prevent reuse.
PWD-04	Passwords must never be shared with any other person, including managers, IT staff, or help desk personnel. IT staff will never ask for a user's password.	Credential sharing eliminates individual accountability, makes audit trails unreliable, and dramatically expands the attack surface. This is a fundamental identity security principle aligned with NIST and ISO 27001.

8.2 Password Screening and Breach Detection

Control	Standard	Rationale and Industry Alignment
PWD-05	All new passwords must be screened against known-compromised credential databases at the time of creation. Passwords found in breach databases must be rejected regardless of length or complexity.	The SANS template requires periodic password cracking by the InfoSec team. This policy modernizes that control by requiring real-time breach screening using tools integrated with HavelBeenPwned (10 billion+ compromised credentials) or equivalent. NIST SP 800-63B Section 5.1.1 explicitly mandates this control.
PWD-06	The InfoSec Team will conduct periodic password audits using approved cracking tools to identify weak or guessable passwords on organizational systems. Users whose passwords are identified as weak will be required to change them immediately.	Retained from the SANS template. Periodic auditing catches passwords that passed initial screening but are weak by pattern. Tools such as Specops Password Auditor provide Active Directory-level visibility into compromised, reused, and weak credentials across the organization.

8.3 Password Expiration and Change Requirements

Control	Standard	Rationale and Industry Alignment
PWD-07	Standard user account passwords do not require mandatory periodic rotation	NIST SP 800-63B and Microsoft both recommend eliminating mandatory rotation

Control	Standard	Rationale and Industry Alignment
PWD-08	unless there is evidence or reasonable suspicion of compromise. Upon confirmed or suspected compromise, passwords must be changed immediately.	cycles. Forced rotation produces predictable incremental changes that provide no real security benefit and increase user friction, leading to weaker overall credential hygiene.
	Privileged and administrative account passwords must be rotated at minimum annually, or immediately upon any personnel change affecting access to those accounts.	Privileged accounts represent the highest-value credential targets. Annual rotation for privileged accounts is a reasonable intermediate control that balances security with operational practicality while aligning with PCI DSS requirements for administrative accounts.

8.4 Multi-Factor Authentication

Control	Standard	Rationale and Industry Alignment
PWD-09	Multi-Factor Authentication (MFA) is mandatory for all email accounts, VPN and remote access, cloud platforms, administrative and privileged accounts, financial systems, and any application processing personal, financial, or sensitive organizational data.	Microsoft data shows MFA prevents over 99.9% of credential-based account compromises. CISA's MFA guidance and PCI DSS v4.0 both mandate MFA for privileged and remote access. MFA is the single most impactful control available for credential security.
PWD-10	Where MFA is implemented, number-matching or phishing-resistant MFA methods (such as FIDO2 hardware keys, passkeys, or authenticator apps with number matching) are required. SMS-based MFA is acceptable only where no alternative is technically feasible and must be documented as an exception.	MFA fatigue and SIM-swapping attacks have made push notification and SMS MFA less reliable. Number matching forces users to actively verify the login attempt. FIDO2 and passkeys are phishing-resistant and represent the current gold standard per CISA and NIST guidance.

8.5 Password Storage and Management

Control	Standard	Rationale and Industry Alignment
PWD-11	All personnel must use the organization's approved enterprise password manager for storing and generating work-related passwords. Passwords must never be stored in plaintext, written on paper, stored in unencrypted files, or saved in browser password managers for organizational accounts.	With an average of 191 work passwords per employee, password managers are the only practical solution to eliminating credential reuse. Enterprise password managers provide encrypted storage, team sharing with audit trails, and breach monitoring. Browser password managers lack enterprise audit capabilities.
PWD-12	Systems must store passwords using approved one-way hashing algorithms with salting, such as bcrypt, Argon2, or PBKDF2. Storing passwords in plaintext, reversible encryption, or using unsalted hashes is prohibited.	Plaintext or weakly hashed password storage turns any database breach into a complete credential compromise. NIST SP 800-63B mandates memory-hard hashing functions. Salting prevents rainbow table attacks. This

Control	Standard	Rationale and Industry Alignment
PWD-13		control protects credentials even if the underlying database is breached.
	Account lockout must be enforced after no more than 10 consecutive failed login attempts. Lockout duration must be at minimum 15 minutes or until reset by IT. Lockout events must be logged and reviewed for patterns indicating brute force attacks.	Account lockout directly counters brute force and credential stuffing attacks. PCI DSS v4.0 requires lockout after no more than 10 failed attempts. Logging lockout events enables detection of automated attack campaigns targeting organizational accounts.

9. Legal and Regulatory Obligations

Framework / Standard	Relevance to This Policy
NIST SP 800-63B Digital Identity Guidelines	Primary technical standard for password length, complexity, screening, expiration, and MFA requirements
NIST Cybersecurity Framework (CSF) 2.0	Protect (PR.AC) function: Identity management, authentication, and access control
CIS Controls v8	Control 5 (Account Management), Control 6 (Access Control Management): password and MFA requirements
PCI DSS v4.0	Requirements 8.2 and 8.3: minimum 12-character passwords, MFA for admin and remote access, account lockout after 10 attempts
ISO/IEC 27001:2022	Annex A.9 (Access Control): authentication management, password policies, privileged access
HIPAA Security Rule	Administrative and technical safeguards requiring unique user identification and authentication controls
GDPR and Applicable State Privacy Laws	Appropriate technical measures to protect personal data, including strong authentication for systems processing personal information

10. Training and Awareness

All personnel must receive password security training appropriate to their role:

- All Employees and Contractors: Annual training on passphrase creation, the approved password manager, MFA enrollment and use, recognizing phishing and credential theft attempts, and the procedure for reporting suspected account compromise.
- System Administrators: Annual training on implementing and enforcing technical password controls in Active Directory and all platforms, configuring account lockout policies, and operating breach screening tools.
- New Hires: Password security training must be completed during onboarding, prior to receiving access credentials. MFA enrollment must be completed on the first day of access.

Training completion records are maintained by the IT Security Team and retained for a minimum of three years.

11. Compliance Measurement

Compliance with this policy is assessed through the following scheduled activities:

Activity	Controls Assessed	Frequency
Password audit using approved cracking tools	PWD-05, PWD-06	Quarterly
Breached password screening report review	PWD-05	Monthly (automated)
MFA enrollment verification	PWD-09, PWD-10	Monthly
Account lockout event log review	PWD-13	Weekly
Privileged account password rotation audit	PWD-08	Annual
Password manager adoption report	PWD-11	Quarterly
Full policy compliance assessment	All PWD controls	Annual

Results are documented and reported to the IT Security Manager. Material non-compliance findings are escalated to senior IT leadership within 5 business days.

12. Exception Management

Legacy systems or operational constraints may occasionally prevent full compliance with specific controls. All exceptions must follow this process:

- The requesting party submits a written exception request to the IT Security Manager documenting the specific control affected, the technical or business justification, proposed compensating controls, and the requested duration (maximum 90 days).
- Exceptions to PWD-09 (MFA requirement) require both IT Security Manager and senior IT leadership approval given the elevated risk of unauthenticated access.
- All approved exceptions are logged in the exception register with compensating controls, approving authority, and expiration date.
- The exception register is reviewed monthly. Expired exceptions not formally renewed are treated as policy violations.

13. Policy Sanctions

Non-compliance with this policy will result in disciplinary action consistent with the organization's human resources policies. Sanctions are applied consistently and proportionally:

Severity	Consequence
Minor / Unintentional	Mandatory refresher training; written notice; increased monitoring for 90 days
Moderate / Negligent	Formal written warning; temporary suspension of affected account access; mandatory review with IT Security Manager
Severe / Willful Violation	Immediate suspension of all system access; HR investigation; potential termination of employment or contract
Criminal / Illegal Activity	All above consequences plus referral to law enforcement; legal action under applicable federal and state statutes

14. Continual Improvement

This policy is reviewed at minimum annually. Earlier review is triggered by any of the following:

- A credential-related security incident or confirmed account compromise
- Publication of updated NIST SP 800-63B guidelines or equivalent standards
- Significant changes to the organization's authentication infrastructure or platform portfolio
- Emergence of new attack techniques targeting organizational credentials
- Findings from internal audits, penetration testing, or third-party assessments

The IT Security Manager coordinates annual reviews and ensures the policy remains aligned with the current threat landscape, applicable regulations, and industry best practices. All revisions are documented and communicated to all in-scope personnel within 10 business days of approval.

15. Sources and References

Source	URL / Reference
SANS Password Construction Standard (April 2025)	https://www.sans.org/information-security-policy/
NIST SP 800-63B Digital Identity Guidelines	https://pages.nist.gov/800-63-3/sp800-63b.html
NIST Cybersecurity Framework (CSF) 2.0	https://www.nist.gov/cyberframework
CIS Controls v8	https://www.cisecurity.org/controls/v8
PCI DSS v4.0	https://www.pcisecuritystandards.org/document_library/
ISO/IEC 27001:2022	https://www.iso.org/standard/82875.html
Microsoft Password Guidance 2025	https://www.microsoft.com/en-us/research/publication/password-guidance/
HavelBeenPwned Breach Database	https://haveibeenpwned.com/Passwords
CISA MFA Guidance	https://www.cisa.gov/mfa

Password Protection Policy

Source	URL / Reference
Verizon 2025 Data Breach Investigations Report	https://www.verizon.com/business/resources/reports/dbir/
Specops: Top 5 Password Security Insights 2026	https://specopssoft.com/blog/top-5-password-security-insights-2026/
AwareGO: Password Security Best Practices 2026	https://awarego.com/password-security-best-practices-the-2026-human-centric-guide/
Deel: Password Policy Guide 2026	https://www.deel.com/blog/password-policy-guide/
Artifice Security: Password Policy Best Practices 2025	https://artificesecurity.com/password-policy-best-practices/
MetaCompliance: Password Policy Best Practices 2026	https://www.metacompliance.com/blog/cyber-security-awareness/password-policy-best-practices